

Medikart

Pharmacy E-Commerce & Pharmacy Management System

Product Requirements Document

Version 3.2

August 2026

Prepared for: Medikart Client

Revision History

Version	Date	Author	Description
0.1	July 2026	Project Team	Initial draft from client requirements gathering
1.0	August 2026	Project Team	Added Narcotics flagging as a first-class feature; full PRD structure with goals, personas, UI direction, and acceptance criteria
2.0	August 2026	Project Team	Renamed to Medikart. Clarified Narcotics is a product-level flag/badge, not a browsable category, per client. Tech stack split: Next.js storefront (SEO) + React/Vite admin. Switched image storage from Cloudinary to self-hosted (VPS + Next.js image optimization + Cloudflare). Added Hosting/Domain/Infrastructure section. Added Admin Product Search (FR-AD-31) and Admin Password Reset (FR-AD-32). Expanded Security NFRs (2FA, CSRF, helmet, firewall/fail2ban, dependency scanning, pre-launch security review). Added SEO & Discoverability subsection. Updated catalog figures to the client's real stock file (6,112 products, 15 categories). Payment Gateway section marked pending final confirmation from Habib Metro.
2.1	August 2026	Project Team	Added Discounts & Promotions (product/category/storewide, most-specific-wins precedence, confirmed by client) with server-side price integrity. Added AI Customer Assistant chatbot (Groq LLM) for symptom-based product suggestions, with mandatory medical disclaimer and a hard exclusion on suggesting Narcotics-flagged products. Added About page, Contact Us page, and WhatsApp click-to-chat icon. Clarified prescription image storage applies identically to Instant Order and Narcotics flows. Promoted admin role management from a future enhancement to a current requirement: Super Admin can create/delete admin accounts and edit their role/module access (FR-AD-37/38).
2.2	August 2026	Project Team	Added Section 16 (Performance, Caching & Testing Strategy), formalizing Redis caching, database indexing/connection pooling, and frontend delivery performance as real requirements rather than conversational notes. Added NFR-PERF-03/04/05 and NFR-TEST-01/02 (unit + integration test coverage expectations, matching the phased delivery plan in phases.md).
3.0	August 2026	Project Team	Added Order Cancellation with automatic void/refund (FR-AD-39, FR-SYS-10) and its own workflow (13.5), plus a mandatory cancellation email (FR-CW-24). Added multiple images per product with a designated primary/cover image

Version	Date	Author	Description
			(FR-AD-40). Client confirms functional scope is complete; this version is the baseline for development kickoff. Payment Gateway technical specifics (Section 15.4) remain the one item still pending Habib Metro's confirmation.
3.1	August 2026	Project Team	Removed the Stripe/Razorpay evaluation section per client request — Habib Metro is the sole payment gateway direction; no comparison to other providers is documented in this PRD.
3.2	August 2026	Project Team	Added Section 17 (Security Protocols), consolidating all security measures into one reference structured around the OWASP API Security Top 10 (2023) and real-world production rate-limiting practice (Stripe/GitHub-style Redis token-bucket limiting). Confirmed and formalized that rate limiting applies to every API endpoint, not only OTP/login/chatbot (NFR-SEC-14). Added explicit object-level, property-level, and function-level authorization requirements (NFR-SEC-15/16/17) addressing OWASP's BOLA, mass-assignment, and BFLA risks.

Table of Contents

1. Executive Summary

- 1.1 Problem Statement
- 1.2 Solution Summary
- 1.3 Catalog Snapshot

2. Goals & Objectives

3. Target Users & Personas

- 3.1 The Guest Shopper
- 3.2 The Prescription Customer
- 3.3 Pharmacy Staff / Admin
- 3.4 The Client (Business Owner)

4. Product Scope

- 4.1 In Scope
- 4.2 Out of Scope (This Phase)

5. Functional Requirements

- 5.1 Customer Website Requirements
- 5.2 Admin Dashboard Requirements
- 5.3 System-Level Requirements

6. Non-Functional Requirements

7. Customer Website Features

8. Admin Dashboard Features

9. Discounts & Promotions

- 9.1 Precedence Rule
- 9.2 Display & Pricing Integrity

10. AI Customer Assistant (Chatbot)

- 10.1 Behavior & Guardrails
- 10.2 Integration Notes

11. Additional Pages & Contact Channels

- 11.1 About & Contact Us
- 11.2 WhatsApp Click-to-Chat

12. Dynamic Narcotics Flagging & Verification

- 12.1 Building the Initial Narcotics List

13. Workflows

- 13.1 Standard Order
- 13.2 Instant Order
- 13.3 Narcotics Order
- 13.4 Narcotics Flagging
- 13.5 Order Cancellation & Refund

14. Database Overview

15. Hosting, Domain & Infrastructure

- 15.1 Hosting
- 15.2 Domain
- 15.3 Product & Prescription Images — Self-Hosted
- 15.4 Payment Gateway

16. Performance, Caching & Testing Strategy

- 16.1 Redis Caching
- 16.2 Database & Query Performance
- 16.3 Frontend Delivery
- 16.4 Testing Strategy

17. Security Protocols

- 17.1 Transport & Network Security
- 17.2 API Rate Limiting — Every Endpoint, Not Just Login/OTP
- 17.3 Authentication & Session Security
- 17.4 Authorization — Object, Property, and Function Level
- 17.5 Input Validation & Injection Prevention
- 17.6 Web Application Protections
- 17.7 File Upload Security
- 17.8 Secrets & Configuration
- 17.9 Payment & Financial Data Security
- 17.10 Dependency & Infrastructure Hardening
- 17.11 Monitoring, Logging & Accountability

18. API Overview

19. UI Requirements

- 19.1 Direction
- 19.2 Requirements
- 19.3 SEO & Discoverability

20. Acceptance Criteria

21. Assumptions & Constraints

22. Future Enhancements

23. Success Metrics

24. User Journeys

- 24.1 Guest Shopper — Standard Order
- 24.2 Prescription Customer — Instant Order
- 24.3 Narcotics Customer
- 24.4 Pharmacy Admin — Narcotics Reclassification

25. Release Plan

26. Risks & Mitigations

27. Screen Inventory

1. Executive Summary

Medikart is a custom Pharmacy E-Commerce and Pharmacy Management System that replaces manual, spreadsheet-driven order handling with a real online store and an internal management dashboard — while still feeding the client's existing Google Sheets workflow so nothing downstream breaks on day one.

The product ships as two connected experiences: a guest-checkout storefront (Next.js, for search-engine visibility) where customers browse and order medicines, and an admin dashboard (React + Vite) where pharmacy staff manage the catalog, process three distinct order types (Standard, Instant, and Narcotics), and run the day-to-day business — including full control over which individual products carry the Narcotics flag.

1.1 Problem Statement

- Customers currently have no self-service way to order medicines online from this pharmacy.
- Order intake, prescription handling, and delivery-cost calculation are manual, error-prone, and hard to scale to a real catalog of 6,112 products across 15 categories.
- Narcotics/controlled-substance orders need a verification step that a generic e-commerce checkout does not provide out of the box.

1.2 Solution Summary

A custom React/Next.js/Node/MongoDB application (not a WordPress or theme-based build) that gives customers a fast, search-engine-visible guest checkout, gives staff a single dashboard to run the pharmacy, and gives the client's existing Google Sheets-based reporting a live, automatic feed — with a purpose-built narcotics verification flow and full admin control over which products require it.

1.3 Catalog Snapshot

Based on the client's actual stock file: 6,112 real products across 15 categories (Medicines, Consumer, Vitamins, Nutraceuticals, Dermatology, Milk & Powder, Surgical, Herbal, Fridge Items, Diagnostics, Diapers & Napkins, Flat Items, Beverages, Patient Supports, General Items, Surgical Furniture — with "Nutra" merged into "Nutraceuticals" as a duplicate). 506 products currently have no category assigned and will need one before launch. Product photography is being generated by the development team using AI rather than supplied by the client.

2. Goals & Objectives

Goal	Success Looks Like
Enable self-service online ordering	A customer can find a medicine, check out as a guest, and receive confirmation — in under a few minutes.
Support prescription-based ordering	A customer with a prescription but no product knowledge can still order via Instant Order.
Enforce narcotics compliance	No narcotics order is fulfilled or card-charged without an approved prescription.
Give staff full catalog control, including narcotics classification	Admins can add/remove the Narcotics flag on any product at any time, with a full audit trail — no engineering involvement required.
Preserve the client's existing reporting workflow	Every order lands correctly in the right Google Sheets tab, and a weekly Excel report is auto-emailed.
Support the client's planned Excel catalog	6,000–8,000 existing products import cleanly with error reporting, not a silent partial import.

3. Target Users & Personas

3.1 The Guest Shopper

Orders medicines for themselves or family, wants to avoid creating an account, may pay COD or by card, and cares most about knowing the total cost (including delivery) before committing.

3.2 The Prescription Customer

Has a doctor's prescription, doesn't necessarily know exact product names/SKUs, and wants to hand off the prescription and let the pharmacy figure out the order (Instant Order) — sometimes for medicines that are narcotics-controlled and require verification.

3.3 Pharmacy Staff / Admin

Processes incoming orders all day, needs to move fast through a dense dashboard, needs to review prescriptions (including narcotics approvals/rejections), assign branches, and keep the product catalog — including which products count as narcotics — accurate as regulations or stock changes.

3.4 The Client (Business Owner)

Wants visibility into sales, wants the existing Google Sheets-based operations to keep working, and wants confidence that narcotics sales are compliant and auditable without needing to involve a developer every time a product's classification changes.

4. Product Scope

4.1 In Scope

- Guest-checkout customer website: browse, search, cart, checkout, OTP verification, COD/card payment, automatic delivery pricing.
- Three order types: Standard, Instant Order, Narcotics (verification-gated).
- Admin dashboard: Overview, Products (incl. Narcotics flagging), Categories, Orders, Cities, Branch Assignment, Sales Reports, Admin Users, Settings, Activity Logs.
- Integrations: MongoDB Atlas, self-hosted image storage, Google Sheets (two worksheets), SMTP email, Habib Metro payment gateway.
- Bulk product import from the client's existing Excel catalog.
- Discounts at product/category/storewide level, with a fixed precedence rule and server-side price integrity.
- AI symptom-assistant chatbot (Groq LLM), About page, Contact Us page, and a WhatsApp click-to-chat icon.
- Super Admin ability to create/delete admin accounts and assign their role/module access.

4.2 Out of Scope (This Phase)

- Customer accounts/login (guest checkout only, by client requirement).
- Automatic low-stock threshold tracking (manual In Stock / Out of Stock only, for now).
- Fixed named role presets beyond Super Admin/Admin (e.g. a dedicated "Sales Manager" preset) — module-level access toggles cover this for now (FR-AD-38); named presets can be layered on later without a data model change.
- Multi-branch inventory allocation (Branch Description is descriptive/manual in this phase).

5. Functional Requirements

The following requirements state, precisely, what the product must do. Each has a unique ID (referenced elsewhere in this document and in the SRS) and a MoSCoW priority (Must / Should / Could). Requirements FR-AD-11 through FR-AD-16 implement the client's Dynamic Narcotics Category Management requirement, detailed further in Section 12.

5.1 Customer Website Requirements

ID	Title	Description	Priority
FR-CW-01	Product Browsing	The system shall allow customers to browse the full product catalog through a responsive, paginated grid.	Must
FR-CW-02	Product Search	The system shall allow customers to search products by name/keyword with results ranked by relevance.	Must
FR-CW-03	Category Browsing	The system shall allow customers to filter/browse products by category.	Must
FR-CW-04	Product Detail View	The system shall display product image, description, price, category, and stock status on a dedicated product page.	Must
FR-CW-05	Add to Cart	The system shall allow customers to add a product to a cart and specify quantity.	Must
FR-CW-06	Update Cart	The system shall allow customers to update quantities or remove items from the cart before checkout.	Must
FR-CW-07	Guest Checkout	The system shall allow order placement without requiring account creation or login.	Must
FR-CW-08	Checkout Details Capture	The system shall capture name, email, phone number, delivery address, city, and optional notes at checkout.	Must
FR-CW-09	Email OTP Verification	The system shall send a one-time password to the customer's email and require it to be entered correctly before the order is accepted.	Must
FR-CW-10	Payment Method Selection	The system shall allow the customer to choose Cash on Delivery or Credit/Debit Card as the payment method.	Must
FR-CW-11	Automatic Delivery Charge	The system shall calculate delivery charge automatically based on the selected city (PKR 250 for configured cities, PKR 500 otherwise), computed server-side.	Must
FR-CW-12	Instant Order Submission	The system shall allow a customer to submit an Instant Order by uploading a prescription and contact/delivery details, without selecting individual products.	Must
FR-CW-13	Narcotics Order Submission	The system shall require prescription upload before a customer can submit an order containing one or more products flagged as narcotics.	Must
FR-CW-14	Narcotics Detection at Cart Level	The system shall automatically detect when a cart contains a product carrying the Narcotics flag and route that order into the narcotics verification workflow, regardless of what other non-flagged items are in the same cart.	Must
FR-CW-15	Order Confirmation Email	The system shall send exactly one order-confirmation email immediately after a Standard, Instant, or Narcotics order is successfully placed.	Must
FR-CW-16	Stock-Aware Ordering	The system shall prevent adding an Out of Stock product to the cart, or clearly flag it as unavailable at checkout.	Should
FR-CW-17	Responsive Layout	The system shall render correctly on mobile, tablet, and desktop viewports.	Must
FR-CW-18	Placeholder Imagery	The system shall display a default placeholder image for any product without an uploaded image.	Must

ID	Title	Description	Priority
FR-CW-19	Discounted Price Display	The system shall display a product's original price struck through alongside the discounted price and a percentage-off badge whenever any discount (product, category, or storewide) applies to it, with the effective price always calculated server-side.	Must
FR-CW-20	About Page	The system shall provide an About page with content editable by an administrator.	Must
FR-CW-21	Contact Us Page	The system shall provide a Contact Us page (address, phone, email, branch list) with content editable by an administrator.	Must
FR-CW-22	WhatsApp Click-to-Chat	The system shall display a persistent WhatsApp icon on every storefront page that opens a chat with the client's WhatsApp Business number via a wa.me link.	Must
FR-CW-23	AI Symptom-Assistant Chatbot	The system shall provide a chatbot (Groq LLM) that suggests relevant over-the-counter products in response to a customer's described symptoms (e.g. "headache" → paracetamol-type products), always accompanied by a disclaimer that it is not a doctor and the customer should consult a pharmacist or physician for precise guidance. The chatbot shall never suggest a product carrying the Narcotics flag, and shall never process or complete a purchase itself.	Must
FR-CW-24	Cancellation Email	The system shall send exactly one cancellation email to the customer immediately when an admin cancels their order, distinct from the single order-confirmation email (FR-CW-15).	Must

5.2 Admin Dashboard Requirements

ID	Title	Description	Priority
FR-AD-01	Dashboard Overview	The system shall display today's orders, pending, packed, delivered, instant, and narcotics order counts, total products, total categories, revenue summary, and a recent-orders feed.	Must
FR-AD-02	New Order Highlighting	The system shall visually highlight orders that have not yet been reviewed by staff, clearing the highlight once opened.	Must
FR-AD-03	Product CRUD	The system shall allow administrators to create, read, update, and delete individual products.	Must
FR-AD-04	Product Activation Toggle	The system shall allow administrators to activate or deactivate a product without deleting it.	Must
FR-AD-05	Product Field Editing	The system shall allow administrators to edit product price, description, category, stock status, and images.	Must
FR-AD-06	Bulk Excel Import	The system shall allow administrators to import products in bulk from an Excel file (target: 6,000–8,000 rows), validating each row and reporting row-level errors.	Must
FR-AD-07	Bulk Excel Export	The system shall allow administrators to export the current product catalog to Excel.	Must
FR-AD-08	Bulk Price Update	The system shall allow administrators to update prices for multiple products in a single bulk operation.	Must
FR-AD-09	Bulk Stock Status Update	The system shall allow administrators to update stock status for multiple products in a single bulk operation.	Must
FR-AD-10	Missing-Image	The system shall provide a filtered view of products that do not yet have an	Should

ID	Title	Description	Priority
	Report	uploaded image.	
FR-AD-11	Add Product to Narcotics Flag	The system shall allow an administrator to mark any existing or newly created product with the Narcotics flag at any time, with the change taking effect immediately for new orders. This is a tag/badge on the product, not a separate browsable category — the product remains listed in its normal category.	Must
FR-AD-12	Remove Product from Narcotics Flag	The system shall allow an administrator to remove the Narcotics flag from a product at any time, after which new orders for that product no longer require prescription verification.	Must
FR-AD-13	Bulk Narcotics Flagging	The system shall allow administrators to select multiple products and add or remove the Narcotics flag in a single bulk action.	Should
FR-AD-14	Narcotics Flagged Products View	The system shall provide a dedicated filtered view listing all products currently carrying the Narcotics flag, independent of the general product list and independent of any display category — this is an audit view, not a customer-facing category.	Must
FR-AD-15	Narcotics Change Audit	The system shall log every addition or removal of the Narcotics flag on a product to Activity Logs, including which admin made the change and when.	Must
FR-AD-16	In-Flight Order Protection	The system shall not retroactively change the verification requirement of an order already placed if a product's Narcotics flag changes after that order was submitted.	Must
FR-AD-17	Category CRUD	The system shall allow administrators to create, edit, and delete product categories without requiring a code change or deployment.	Must
FR-AD-18	Standard Orders View	The system shall list Standard orders with full customer information, items, quantities, totals, payment method, status, and timestamps.	Must
FR-AD-19	Instant Orders View	The system shall list Instant Orders showing the uploaded prescription and customer information, and allow staff to add medicines and a total amount after review.	Must
FR-AD-20	Narcotics Orders View	The system shall list Narcotics orders with the current verification status and allow staff to approve or reject the uploaded prescription.	Must
FR-AD-21	Order Status Update	The system shall allow administrators to progress an order's status (e.g. Pending → Packed → Shipped → Delivered).	Must
FR-AD-22	City CRUD	The system shall allow administrators to add, edit, and delete delivery cities and their associated delivery charge.	Must
FR-AD-23	Branch Assignment	The system shall allow administrators to assign or update a Branch Description on any order.	Must
FR-AD-24	Sales Summary Cards	The system shall display today's revenue, monthly revenue, and order-count summaries.	Must
FR-AD-25	Best Sellers & Top Categories	The system shall report best-selling products and top-performing categories over a selectable date range.	Should
FR-AD-26	Trend Charts	The system shall display daily order trend and monthly revenue charts.	Should
FR-AD-27	Report Export	The system shall allow sales reports to be exported to Excel and PDF.	Should
FR-AD-28	Multiple Admin Users	The system shall support multiple concurrent administrator accounts.	Must
FR-AD-29	Settings Management	The system shall provide a Settings module covering General, Delivery, Payment, Email, Order, Prescription, Google Sheets, Image Storage, Security,	Must

ID	Title	Description	Priority
		and Backup configuration.	
FR-AD-30	Activity Logs	The system shall record product updates, price changes, deletions, narcotics flag changes, prescription decisions, order status updates, and admin password resets with actor and timestamp.	Must
FR-AD-31	Admin Product Search	The system shall allow administrators to search the product list by name, SKU, or generic name, in addition to the existing category and Narcotics filters.	Must
FR-AD-32	Admin Password Reset	The system shall allow an administrator who cannot log in to request a password reset via a short-lived, single-use emailed link, without ever transmitting the new or existing password by email.	Must
FR-AD-33	Product-Level Discount	The system shall allow an administrator to apply a percentage discount to an individual product, overriding any category or storewide discount on that product.	Must
FR-AD-34	Category-Level Discount	The system shall allow an administrator to apply a percentage discount to a category, applying to every product in it that does not have its own product-level discount.	Must
FR-AD-35	Storewide Discount	The system shall allow an administrator to apply a single percentage discount across the entire catalog, applying to any product that has neither a product-level nor a category-level discount active.	Must
FR-AD-36	Remove Discount	The system shall allow an administrator to remove a discount at any level (product, category, or storewide); the product's effective price then falls back to the next-broadest active discount, or its full price if none remain.	Must
FR-AD-37	Super Admin Creates/Deletes Admin Accounts	The system shall allow a Super Admin to create new admin accounts and delete existing ones; a regular Admin account shall not be able to create, delete, or edit other admin accounts.	Must
FR-AD-38	Super Admin Edits Admin Roles & Access	The system shall allow a Super Admin to assign or change a role and module-level access (e.g. Products, Orders, Narcotics approval, Reports, Settings) for any admin account, and to activate/deactivate an account without deleting it.	Must
FR-AD-39	Order Cancellation	The system shall allow an administrator to cancel an order that has not yet shipped (Pending or Packed status), with an optional reason, e.g. an out-of-stock medicine discovered during fulfillment.	Must
FR-AD-40	Multiple Product Images	The system shall allow an administrator to upload more than one image for a single product and designate one as the primary/cover image shown in listings.	Must

5.3 System-Level Requirements

ID	Title	Description	Priority
FR-SYS-01	MongoDB Persistence	The system shall persist all products, categories, cities, orders, and configuration in MongoDB Atlas.	Must
FR-SYS-02	Self-Hosted Image Storage	The system shall store product images and prescription uploads on the application server, with every upload compressed/optimized (resize, WebP conversion) before saving. Prescription uploads shall be kept outside any public route and reachable only through an authenticated admin endpoint.	Must
FR-SYS-03	Google Sheets Sync — Standard	The system shall write every Standard order to the Standard Orders worksheet with all required columns, including Branch Description.	Must
FR-SYS-04	Google Sheets Sync — Instant	The system shall write every Instant order to the Instant Orders worksheet with all required columns, including Branch Description.	Must

ID	Title	Description	Priority
FR-SYS-05	Sync Resilience	The system shall queue and retry Google Sheets writes so a temporary API failure never blocks order placement.	Must
FR-SYS-06	Weekly Excel Report	The system shall automatically generate and email a weekly Excel report of orders for a configurable date range.	Must
FR-SYS-07	Admin Notification	The system shall push a real-time notification to the admin dashboard whenever a new order is placed.	Must
FR-SYS-08	Deferred Narcotics Payment Capture	The system shall defer card payment capture on a narcotics order until the prescription has been approved.	Must
FR-SYS-09	Deferred-Capture Timeout Handling	The system shall define and enforce a maximum verification window after which an unapproved narcotics card-payment order is automatically cancelled and the customer notified.	Should
FR-SYS-10	Automatic Refund/Void on Cancellation	When an order is cancelled (FR-AD-39), the system shall automatically void the payment if it was only authorized/held, or issue a refund via the gateway if it was already captured — never a manual, out-of-band refund process, and never requiring the order to have been paid by any method other than what the customer originally used.	Must

6. Non-Functional Requirements

Non-functional requirements describe how the system must behave, not just what it must do — performance, security, compliance, reliability, usability, and maintainability targets that apply across every feature above.

ID	Category	Requirement
NFR-PERF-01	Performance	Product listing and search pages shall return results within 2 seconds under normal load (catalog of up to 8,000 products).
NFR-PERF-02	Performance	The admin dashboard order list shall paginate/server-filter rather than loading the full order history client-side.
NFR-SCAL-01	Scalability	The backend API shall run under a process manager (PM2) in cluster mode to scale across available CPU cores.
NFR-SCAL-02	Scalability	The data model shall support adding new pharmacy branches without a schema migration.
NFR-SEC-01	Security	All traffic shall be served over HTTPS with a valid SSL certificate (Let's Encrypt), auto-renewed, with HSTS enabled so browsers refuse to downgrade to HTTP.
NFR-SEC-02	Security	Admin passwords shall be stored using a salted one-way hash (bcrypt); plaintext passwords shall never be logged, stored, or emailed — including during password reset (FR-AD-32).
NFR-SEC-03	Security	OTP codes and password-reset tokens shall expire quickly (OTP: 10 minutes; reset link: 30 minutes), be single-use, and be rate-limited per email/IP to prevent brute force.
NFR-SEC-04	Security	Prescription and product images shall be validated for true file type (not extension alone) and size before upload is accepted.
NFR-SEC-05	Security	All admin-only routes shall require authentication by default (allow-list, not block-list, for public endpoints).
NFR-SEC-06	Security	Secrets (DB URI, SMTP credentials, Habib Metro gateway keys, JWT signing secret) shall live only in an untracked .env file per environment, never committed to source control.
NFR-SEC-07	Security	Only a Super Admin account shall be able to create, delete, or edit another admin account's role/access; a regular Admin account shall not be able to escalate its own privileges.
NFR-SEC-08	Security	Admin accounts shall support two-factor authentication (2FA), given the dashboard approves narcotics orders and handles payment references.
NFR-SEC-09	Security	Session cookies shall be HttpOnly, Secure, and SameSite; admin state-changing requests shall be protected against CSRF.
NFR-SEC-10	Security	The application shall set standard security response headers (via helmet.js or equivalent) covering clickjacking, MIME-sniffing, and a Content-Security-Policy.
NFR-SEC-11	Security	The VPS shall restrict inbound network access to required ports only (firewall), use key-based SSH authentication with password login disabled, and auto-ban IPs after repeated failed SSH attempts (fail2ban).
NFR-SEC-12	Security	Dependencies shall be scanned for known vulnerabilities (npm audit / Dependabot) on an ongoing basis, not only at initial build.
NFR-SEC-13	Security	A security review (at minimum an automated scan such as OWASP ZAP against staging) shall be completed before the site accepts real customer payments.

ID	Category	Requirement
NFR-SEC-14	Security	Every API endpoint, not only OTP/login/chatbot, shall be rate-limited via Redis-backed counters (token-bucket style), with tighter limits on sensitive/write endpoints and more generous limits on public read endpoints; a client exceeding its limit receives 429 with a Retry-After header, never a silent hang or crash.
NFR-SEC-15	Security	Every object-returning endpoint shall verify the requesting user/admin actually owns or is authorized to access that specific object (order, admin account, etc.), not just that they are authenticated in general — preventing ID-manipulation access to someone else's data (OWASP API1: Broken Object Level Authorization).
NFR-SEC-16	Security	Every write endpoint shall accept only an explicit allow-list of fields per request type; fields like isNarcotic, price, or role shall never be settable through a request meant for an unrelated purpose, even if included in the payload (OWASP API3: Broken Object Property Level Authorization / mass assignment).
NFR-SEC-17	Security	Role-restricted endpoints (e.g. Super-Admin-only routes) shall enforce that check at the function level on every request, not only hide the option in the UI — a regular Admin calling the API directly shall still be rejected.
NFR-COMP-01	Compliance	The Narcotics flag shall enforce prescription verification before dispensing, consistent with applicable pharmacy regulation for controlled substances.
NFR-COMP-02	Compliance	Every Narcotics flag change and every prescription approval/rejection shall be independently auditable via Activity Logs.
NFR-COMP-03	Compliance	The AI chatbot (FR-CW-23) shall never recommend a product carrying the Narcotics flag and shall always include a disclaimer directing the customer to a pharmacist or doctor; every chatbot conversation shall be logged for periodic review.
NFR-REL-01	Reliability	Order placement shall succeed and be persisted to MongoDB even if the Google Sheets sync or email send temporarily fails (both are queued/retried, not inline-blocking).
NFR-REL-02	Reliability	The system shall target 99.5% uptime during business hours, excluding scheduled maintenance.
NFR-AVAIL-01	Availability	MongoDB Atlas shall run automated daily backups; a scripted backup job shall provide an additional recovery point per the Settings > Backup configuration.
NFR-USAB-01	Usability	The customer checkout flow shall be completable in 4 steps or fewer (Details → OTP → Payment → Confirm).
NFR-USAB-02	Usability	The admin dashboard shall support keyboard navigation and sortable/filterable data tables for high-volume order processing.
NFR-USAB-03	Usability	The interface shall respect the user's `prefers-reduced-motion` setting; no animation shall block or delay a user action.
NFR-MAIN-01	Maintainability	The codebase shall follow a feature-based module structure (see architecture/folder structure) so new order types or categories can be added without touching unrelated modules.
NFR-MAIN-02	Maintainability	Category and city configuration (including narcotics flagging) shall be fully data-driven and require no code deployment to change.
NFR-PORT-01	Portability	The storefront (Next.js) and admin dashboard (React/Vite) shall both be deployable behind any standard reverse proxy (Nginx), not tied to a specific hosting vendor.
NFR-LOC-01	Localization	Currency shall be displayed in PKR; city list and delivery pricing shall be configurable for the Pakistani market.
NFR-OBS-01	Observability	The backend shall log errors with enough context (route, actor, entity id) to diagnose

ID	Category	Requirement
		issues without exposing secrets or customer PII in logs.
NFR-PERF-03	Performance	Frequently-read, infrequently-changed data (product listings, category listings, effective discount prices) shall be cached in Redis with a short TTL, so repeat requests do not hit MongoDB unnecessarily.
NFR-PERF-04	Performance	MongoDB collections shall have indexes on every field used for search, filtering, or status lookups (product name/SKU, order status/type, category); query plans shall be reviewed before launch to confirm indexes are actually used.
NFR-PERF-05	Performance	The backend shall reuse pooled MongoDB connections rather than opening a new connection per request.
NFR-TEST-01	Testing	Business logic where a silent bug would cause financial or compliance harm — discount precedence, delivery-charge calculation, the narcotics verification gate, and OTP verification — shall have automated unit test coverage, not rely on manual QA alone.
NFR-TEST-02	Testing	Each of the nine core workflows shall have at least one automated integration test covering its happy path and one covering a realistic failure path (e.g. a rejected narcotics prescription), run before any production deployment.

7. Customer Website Features

Feature	What it does	Why it matters
Product Browsing & Search	Search by name, browse by category, responsive grid.	Fast path to the medicine a customer already knows they need.
Product Detail	Image, description, price, stock status.	Enough information to buy with confidence, even with placeholder images pre-launch.
Cart & Guest Checkout	Add/update items; check out with name, email, phone, address, city, notes — no account.	Removes the #1 friction point for a one-off medicine purchase.
Email OTP Verification	One-time code confirms a real, reachable customer before the order is accepted.	Trust and fraud protection without requiring a login.
Payment Choice	Cash on Delivery or Credit/Debit Card.	Matches how Pakistani pharmacy customers actually expect to pay.
Automatic Delivery Pricing	PKR 250 for configured cities, PKR 500 otherwise, computed server-side.	Consistent, tamper-proof pricing with zero manual calculation.
Instant Order	Upload a prescription, skip manual product search; staff fill in items after review.	Serves customers who have a prescription but don't know exact product names.
Narcotics Ordering	Any cart containing a narcotics-flagged product is automatically routed into prescription verification.	Keeps the pharmacy compliant without extra customer-facing complexity.
Single Confirmation Email	One email sent immediately after order placement.	Clear, uncluttered communication — more emails added only if the client asks.

8. Admin Dashboard Features

Feature	What it does	Why it matters
Overview	Today's/pending/packed/delivered/instant/narcotics counts, totals, revenue, recent orders, unreviewed-order highlighting.	One screen tells staff exactly where today stands.
Products	Full CRUD, activation toggle, bulk Excel import/export, bulk price/stock updates, missing-image view, multiple images per product with a designated primary/cover image.	Manages a 6,000–8,000 SKU catalog without touching code, and lets a product show more than one angle/photo.
Narcotics Flagging	Add or remove the Narcotics flag on any product, individually or in bulk, with a dedicated filtered view and a full audit trail. Not a browsable category — flagged products stay in their normal category with a status badge.	Direct client requirement — compliance control that doesn't require a developer, ever.
Categories	Full CRUD on display categories.	Catalog structure can evolve with the business.
Orders (3 sections)	Standard, Instant, Narcotics — each with full customer/payment/status detail, plus cancellation (with automatic void/refund) for any order that hasn't shipped yet.	Matches the three distinct real-world fulfillment processes, and handles the real-world case of an out-of-stock medicine discovered after an order is placed.
Cities	Full CRUD on delivery cities and charges.	Delivery pricing logic lives in data, not code.
Branch Assignment	Assign/update a branch on any order, synced to Google Sheets.	Keeps the client's branch-routing process intact.
Sales Reports	Revenue summaries, best sellers, top categories, trend charts, Excel/PDF export.	Business visibility without a separate BI tool.
Discounts & Promotions	Apply a percentage discount at product, category, or storewide level (Section 9); remove any of them just as easily.	Runs sales without a developer, at whatever level makes sense.
Admin Users	Super Admin creates/deletes other admin accounts and assigns their role/module access; a regular Admin cannot manage other accounts.	Multiple staff can work the dashboard at once, without every account having full access.
Settings	General, Delivery, Payment, Email, Order, Prescription, Sheets, Image Storage, Security, Backup, Discount, Pages (About/Contact content).	Central configuration, no hard-coded values.
Activity Logs	Every significant action logged with actor and timestamp — including every narcotics flag change, discount change, and admin-account change.	Accountability across multiple admins and a defensible compliance record.

9. Discounts & Promotions

Client requirement: discounts can be applied at three levels — a single product, a whole category, or the entire catalog — and removed just as easily, with a percentage of the admin's choosing (e.g. 4%, 5%, 6%).

9.1 Precedence Rule

Note: Confirmed with the client: the most specific discount wins. A product-level discount overrides a category-level discount, which overrides a storewide discount. Discounts never stack.

- Product-level: set on an individual product's edit screen — takes priority over everything else for that product.
- Category-level: set once on a category — applies to every product inside it that doesn't have its own product-level discount.
- Storewide: one setting in Settings — applies to any product that has neither a product-level nor a category-level discount active.
- Removing a discount at any level simply falls back to the next-broadest one still active, or full price if none remain — "remove" and "apply 0%" are the same action, not a separate feature.

9.2 Display & Pricing Integrity

On the storefront, a discounted product shows its original price struck through next to the new price, plus a percentage-off badge — for example:

PKR ~~3,850~~ **PKR 2,200** 43% OFF

Note: The effective (discounted) price is always calculated server-side, at the moment of display and again at the moment of checkout — never trusted from the customer's browser. This is the same principle already applied to the delivery-charge calculation (FR-CW-11); a price is not something the client is ever allowed to assert on its own.

10. AI Customer Assistant (Chatbot)

Client requirement: a chatbot (Groq LLM — free API tier) that helps a customer find a relevant over-the-counter product from a described symptom, e.g. a customer typing "something for headache" gets pointed toward paracetamol-type products. This mirrors a chatbot already built for the client's earlier PharmaCare project, being adapted to Medikart's catalog and narcotics rules rather than built from scratch.

10.1 Behavior & Guardrails

Note: This is a product-discovery aid, not a medical or purchasing agent. Three rules are non-negotiable given what it's suggesting to real customers:

- Every response includes a clear disclaimer that the assistant is not a doctor, and the customer should consult a pharmacist or physician for precise guidance — never omitted, never just a one-time notice at the start of the conversation.
- The chatbot shall never suggest a product carrying the Narcotics flag (FR-CW-23) — its product search is filtered to exclude flagged products entirely, not just discouraged from mentioning them.
- The chatbot only suggests products and links to their page — it never adds to cart, checks out, or completes a purchase on the customer's behalf.
- Every conversation is logged (sessionId, messages, products suggested) so the client can periodically review what the assistant has been recommending — an ordinary quality/compliance check, not a surveillance feature.

10.2 Integration Notes

- Groq's API is used for its free tier — worth monitoring usage against Groq's rate limits as traffic grows, and treating the specific model/prompt as something to revisit once real conversation logs are available.
- The assistant is scoped to product suggestions from Medikart's own catalog only — it does not answer general medical questions unrelated to finding a product.

11. Additional Pages & Contact Channels

11.1 About & Contact Us

Two standard static pages — About (company background) and Contact Us (address, phone, email, branch list) — with their content editable by an admin through Settings, so the client can update wording or branch details later without needing a developer.

11.2 WhatsApp Click-to-Chat

A persistent WhatsApp icon appears on every storefront page and opens a chat directly with the client's WhatsApp Business number via a wa.me link — no WhatsApp Business API, no Meta approval process, and no added cost. This is click-to-chat only: it opens WhatsApp with the client's number ready to message, it does not send automated order notifications through WhatsApp.

Note: Worth flagging clearly: automating order confirmations or status updates through WhatsApp itself (rather than a customer manually messaging the client) would require the separate WhatsApp Business Platform API — a paid, Meta-approved integration, and a materially bigger scope than the click-to-chat icon requested here. Out of scope unless the client asks for it specifically.

12. Dynamic Narcotics Flagging & Verification

Note: Client clarification: there is NO separate, browsable "Narcotics" category on the storefront. A narcotics product stays listed in its normal category (e.g. "Medicines") and instead carries a visible "Narcotics" flyer/badge — the same label-stub UI pattern used for stock status. Ordering it requires a prescription upload and admin verification. Admin retains full CRUD to add or remove this flag on any product, at any time.

What this means in practice for the client's day-to-day operation:

- Any product can be flagged or unflagged as Narcotics at any time — one product at a time, or several at once via bulk selection — directly from the Products screen. This never creates or removes a category; it only sets a badge on the product.
- The change is live immediately: the storefront checkout starts (or stops) requiring prescription verification for that product on the very next order, with no deployment or waiting period.
- A dedicated Narcotics filtered view shows every currently flagged product in one place — an internal audit view for staff, not a customer-facing browsing category.
- Every add/remove action is recorded in Activity Logs — who changed it, what changed, and when — so the client has a clean compliance record if ever questioned.
- Orders already placed are not retroactively affected by a later flag change — an order keeps the verification requirement that applied when the customer submitted it.

12.1 Building the Initial Narcotics List

The client will provide the authoritative list of narcotics products manually, rather than relying purely on automated detection — the right call for something with legal weight. As a cross-check, a keyword scan against product/generic names was run across the full 6,112-product catalog and returned 70 candidate matches; this candidate list is used only to sanity-check the client's manual list for gaps, not as the source of truth.

This directly supports the Narcotics Order workflow (Section 13.3): the flag on the product is what determines, at the moment of checkout, whether an order gets routed into prescription verification before it can be fulfilled or card-charged.

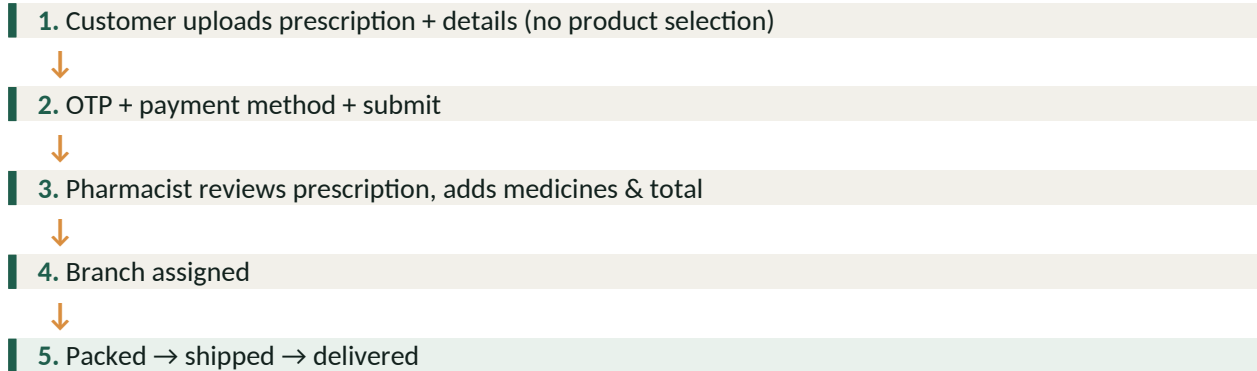
13. Workflows

Full step-by-step workflow diagrams are maintained in the companion Workflow Document; this section summarizes the workflows most relevant to the product experience.

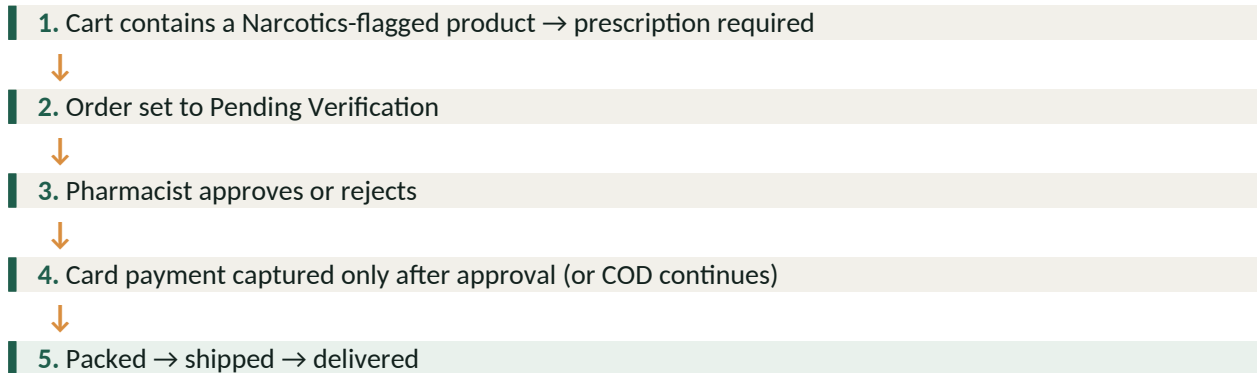
13.1 Standard Order



13.2 Instant Order



13.3 Narcotics Order



13.4 Narcotics Flagging

1. Admin selects a product (or several)



2. Admin adds or removes the Narcotics flag



3. Change is live immediately and logged to Activity Logs



4. Future checkouts reflect the new classification instantly

13.5 Order Cancellation & Refund

1. Admin opens a Pending or Packed order (e.g. a medicine turns out to be out of stock)



2. Admin cancels the order, with an optional reason



3. System checks payment state: COD → nothing to reverse; card authorized-only → void the hold; card already captured → refund via the gateway



4. Order status set to Cancelled; Activity Log entry recorded



5. Cancellation email sent to the customer (distinct from the order-confirmation email)

14. Database Overview

MongoDB Atlas (Flex tier at launch, upgrading to a Dedicated tier as order volume grows) stores the system's data. At a product level, the collections relevant to the day-to-day experience are:

Collection	Representative Fields
products	name, description, price, sku, categoryIds[], isNarcotic (boolean flag, not a category), stockStatus (in_stock/out_of_stock), images[] (self-hosted paths under /uploads/products/{sku}/, each with an isPrimary flag — multiple images per product supported), discount{type:'percentage', value, active}?, active, createdAt, updatedAt
categories	name, slug, isNarcotic (default flag new products may inherit), discount{value, active}?, active
cities	name, deliveryCharge, active
orders	type (standard/instant/narcotics), customer{name,email,phone,address,city}, items[], totals, paymentMethod, status (incl. cancelled), packed, branchDescription, prescriptionUrl?, requiresVerification (boolean, snapshotted at order time), verification{status, reviewedBy, reviewedAt}?, cancellation{reason, cancelledBy, cancelledAt, refundStatus}?, paymentState (authorized/captured/voided/refunded), gatewayTransactionId?, createdAt, updatedAt
otps	email, codeHash, expiresAt, verified, attempts
adminUsers	name, email, passwordHash, role (super_admin/admin), permissions[] (module-level access, editable by Super Admin), twoFactorSecret?, active
passwordResets	adminUserId, tokenHash, expiresAt, used — powers FR-AD-32, mirrors the otps pattern
activityLogs	actor, action, entityType, entityId, before, after, timestamp
settings	group (general/delivery/payment/email/order/prescription/sheets/images/security/backup/discount/pages), values{} — 'pages' holds About/Contact content, 'discount' holds the storewide discount
chatbotConversations	sessionId, messages[] (customer text + bot response), suggestedProducts[], timestamp — logged per NFR-COMP-03 for periodic review
narcoticsAudit	productId, action (added/removed), actor, timestamp — denormalized subset of activityLogs for fast narcotics-history queries

Note: Two fields directly implement Section 12: isNarcotic on products (the admin-controlled flag) and requiresVerification on orders (a snapshot that protects already-placed orders from later flag changes).

15. Hosting, Domain & Infrastructure

15.1 Hosting

- A KVM-based VPS (2 vCPU / 8GB RAM tier) running Ubuntu, with Nginx as reverse proxy/SSL termination and PM2 keeping the Next.js storefront and Express API running as managed, auto-restarting processes — there is no "sleep after inactivity" behavior; the server runs continuously.
- The React/Vite admin dashboard builds to static files, served directly by Nginx — no separate process needed for it.
- Cloudflare sits in front of the VPS (free tier): DDoS protection, a basic firewall, and edge caching for static assets and product images.

15.2 Domain

Registered to match the Medikart brand — either medikart.pk / medikart.com.pk (stronger local trust signal, requires proof of Pakistani business presence) or medikart.com (simpler registration, most globally recognized), or both, with one redirecting to the other.

15.3 Product & Prescription Images — Self-Hosted

Images are stored on the VPS itself rather than a third-party media service. Every upload — the client's initial bulk photo set or a single image added later through the admin dashboard — passes through a compression step (resize, convert to WebP) before being saved, keeping storage and bandwidth costs low without sacrificing load speed. Product images are served through Next.js's built-in image optimization and cached at Cloudflare's edge. Prescription images — both from the Instant Order flow and the Narcotics flow — are saved to a separate, non-public folder on the same server and are reachable only through an authenticated admin endpoint, never a direct public URL.

Note: This replaces a third-party image CDN (e.g. Cloudinary) as the default plan — chosen because Next.js's image handling plus Cloudflare's free CDN already cover resizing and edge delivery, at a fraction of the recurring cost for a catalog of this size.

15.4 Payment Gateway

The client's bank (Habib Metro) will provide a merchant payment gateway. Regardless of the specific provider, the integration must satisfy: (1) card data never passes through or is stored on our server — hosted checkout or hosted fields only; (2) payment confirmation is verified via a signed server-to-server callback, never trusted from a browser redirect alone; (3) authorize-now/capture-later support, required for the narcotics deferred-payment rule (Section 13.3). Full technical details are pending confirmation from the bank and will be finalized in a targeted follow-up revision of this document.

16. Performance, Caching & Testing Strategy

Client requirement: the site must feel fast at every step — a slow product search or a slow checkout directly costs sales, more so for a pharmacy where a customer often wants a medicine quickly. This section formalizes what was previously discussed conversationally into real requirements (NFR-PERF-03 through NFR-PERF-05, NFR-TEST-01/02).

16.1 Redis Caching

A Redis instance sits between the API and MongoDB for data that's read constantly but doesn't change every second:

- Product catalog & search results — cached with a short TTL (e.g. 60 seconds), so a 6,112-product catalog under real traffic mostly hits cache, not the database.
- Effective discount prices (Section 9) — the product/category/storewide precedence calculation runs on every product view; caching its result avoids repeating that work needlessly.
- OTP and session storage, and rate-limit counters (login, OTP, chatbot) — naturally short-lived data that Redis handles faster than a database round-trip, and the shared counters are what makes rate limiting work correctly across multiple server processes (PM2 cluster mode, Section 15.1).

16.2 Database & Query Performance

- Indexes on every field actually used for search/filter/status lookups — product name and SKU, order status and type, category — reviewed before launch to confirm they're really being used, not just declared.
- Pooled MongoDB connections, reused across requests rather than opened fresh each time.
- Admin order lists are paginated/server-filtered (already required, NFR-PERF-02) rather than loading full history client-side.

16.3 Frontend Delivery

- Next.js server-rendering (Section 18.3) means a product page arrives with real content already in the HTML, not assembled after a blank load.
- Next.js's automatic per-route code splitting keeps the admin dashboard's code out of the customer storefront bundle, and vice versa.
- Images compressed to WebP at upload and served through Next.js's image optimization, cached at Cloudflare's edge (Section 15.3) — so repeat image requests are answered close to the customer, not from the origin VPS.

16.4 Testing Strategy

Note: Not every line of code needs a test — but the handful of places where a silent bug means lost money or a compliance failure do.

- Unit tests on: discount precedence (Section 9.1), delivery-charge calculation, the narcotics verification gate (Section 12), and OTP verification — see the phased delivery plan (phases.md) for exactly where each is introduced.
- Integration tests covering each of the nine core workflows' happy path and at least one realistic failure path (e.g. a rejected narcotics prescription, a failed payment).

- A security scan (e.g. OWASP ZAP against staging) and a full run-through of every Acceptance Criterion in this document (Section 20) before production deployment — both already reflected in phases.md as dedicated phases, not left implicit.

17. Security Protocols

This section consolidates every security measure across the system into one reference, structured around the OWASP API Security Top 10 (2023) — the industry-standard checklist for exactly the kind of REST API this project is built on — plus the transport, infrastructure, and payment-specific protocols already established elsewhere in this document. Nothing here is new policy; it is the existing NFR-SEC requirements (Section 6) and Section 16 organized as a single security reference, with the rate-limiting approach specifically modeled on how production API providers (Stripe, GitHub, Cloudflare) actually run theirs, not just OWASP's general guidance.

17.1 Transport & Network Security

- HTTPS enforced everywhere (Let's Encrypt SSL), with HTTP requests redirected and HSTS set so a browser refuses to downgrade even if asked to.
- Cloudflare in front of the VPS: DDoS absorption, a basic Web Application Firewall, and edge caching — the same pattern used by most production APIs to keep abusive traffic from ever reaching the origin server.
- VPS firewall restricts inbound access to required ports only; SSH is key-only (no password login), with fail2ban auto-banning IPs after repeated failed attempts.

17.2 API Rate Limiting — Every Endpoint, Not Just Login/OTP

Note: Direct answer: yes, this is included. Every API route is rate-limited, not only the sensitive ones — the difference is how strict the limit is per route, not whether one exists.

The approach follows the same pattern used by Stripe and GitHub in production: a Redis-backed token-bucket limiter (Stripe's own engineering write-ups describe exactly this — a per-account bucket in Redis, a token removed per request, refilled at a steady rate), which tolerates normal bursts of legitimate traffic while still capping abuse. Key design points:

- Global baseline limit applied to every endpoint by default — nothing is unlimited or forgotten (this is precisely OWASP's API4: Unrestricted Resource Consumption, the modern name for what used to be called "lack of rate limiting").
- Tighter, endpoint-specific overrides on sensitive routes: OTP requests, login attempts, password reset, and the chatbot endpoint get materially stricter limits than a public product listing call — mirroring how Stripe applies much lower per-endpoint limits on top of its global cap for specific sensitive operations.
- Rate limiting keys on a composite of IP + account/session, not IP alone — protects against both a single attacker and the case of many legitimate users sharing one IP (office network, mobile carrier NAT), a known failure mode called out in current API security guidance.
- A client that exceeds its limit receives HTTP 429 with a Retry-After header — a clear, standard signal, not a silent failure or an unrelated error.
- Counters live in Redis specifically so limits are enforced correctly across all PM2 cluster processes — a per-process in-memory counter would let an attacker bypass the limit just by hitting a different process.

17.3 Authentication & Session Security

- Admin passwords hashed with bcrypt; plaintext never logged, stored, or emailed at any point, including password reset.

- Two-factor authentication available on admin accounts, given the dashboard approves narcotics orders and handles payment references.
- OTP and password-reset tokens are short-lived and single-use (OWASP API2: Broken Authentication is specifically about weak session/token handling like this).
- Session cookies are HttpOnly, Secure, and SameSite; admin state-changing requests carry CSRF protection.

17.4 Authorization — Object, Property, and Function Level

Three distinct OWASP API risks are addressed explicitly, since they are the most common real-world API breach pattern and easy to miss if authorization is only checked "is this user logged in" rather than "is this user allowed to touch this specific thing":

- Object-level (API1 — BOLA): every endpoint that returns or modifies a specific record (an order, an admin account) verifies the requester actually owns or is authorized for that exact object — not just that they're authenticated in general. This is what stops someone from changing an order ID in a request and pulling up a stranger's order.
- Property-level / mass assignment (API3 — BOPLA): every write endpoint accepts an explicit allow-list of fields for that request type. A checkout request cannot set isNarcotic or price, no matter what's included in the payload — those fields simply aren't recognized outside the admin product-edit endpoint that's supposed to touch them.
- Function-level (API5 — BFLA): Super-Admin-only actions (creating/editing other admins, per FR-AD-37/38) are enforced in the backend on every request, not just hidden from the menu in the UI — a regular Admin calling that API route directly is still rejected.

17.5 Input Validation & Injection Prevention

- Every request body is validated against a schema (zod/Joi) before it reaches any business logic — malformed or unexpected input is rejected at the door, not handled defensively deeper in the code.
- MongoDB access goes through Mongoose's parameterized queries exclusively — no hand-built query strings from user input, which is what prevents NoSQL injection.
- Maximum payload sizes are enforced (request body size, array lengths, upload size) — an unbounded payload is itself a resource-consumption attack per OWASP API4.

17.6 Web Application Protections

- Standard security headers via helmet.js: clickjacking protection, MIME-sniffing prevention, and a Content-Security-Policy.
- Output is escaped by default (React/Next.js); anywhere raw HTML must render (e.g. rich product descriptions), it is explicitly sanitized rather than trusted.

17.7 File Upload Security

- Every upload (product image, prescription) is validated by real file content/type, not by trusting the filename extension, and capped at a maximum size.
- Prescription uploads are stored outside any public route, reachable only through an authenticated admin endpoint — never a guessable public URL.

17.8 Secrets & Configuration

- All credentials (DB URI, Redis URL, SMTP, Habib Metro keys, JWT signing secret, Groq API key) live only in an untracked .env per environment, never committed to source control — enforced by .gitignore and covered explicitly in the Folder Structure document.
- Security misconfiguration (OWASP API8) is guarded against by keeping environment-specific config out of code entirely — nothing environment-dependent is hard-coded.

17.9 Payment & Financial Data Security

- Card data never touches our server — hosted checkout/fields only (Section 15.4), which keeps PCI-DSS scope at the lowest tier (SAQ A) rather than taking on full cardholder-data handling obligations.
- Payment confirmation is only ever trusted from a signed, verified server-to-server webhook — never a browser redirect alone, which is what prevents a forged "payment succeeded" request.
- Order cancellation (Section 13.5) triggers an automatic void or refund through the gateway using the original transaction reference — no manual, out-of-band handling of payment data at any point.

17.10 Dependency & Infrastructure Hardening

- Dependencies scanned on an ongoing basis (npm audit / Dependabot), not only when the project is first built — a vulnerable package discovered after launch is still caught.
- An automated security scan (OWASP ZAP or equivalent against staging) is a required, non-optional step before the site accepts real customer payments (Phase 27, phases.md).

17.11 Monitoring, Logging & Accountability

- Every significant admin action — product edits, narcotics flag changes, discount changes, order cancellations, admin account changes — is written to Activity Logs with actor and timestamp, giving a full audit trail if anything is ever questioned.
- Errors are logged with enough context to diagnose an issue (route, actor, entity id) without ever writing secrets or customer PII into logs.
- Repeated rate-limit rejections on a single account/IP are themselves a signal worth watching — a spike in 429 responses is often the earliest indicator of scanning or credential-stuffing activity, and is treated as something to monitor, not just silently throttle.

18. API Overview

The backend exposes a versioned REST API under `/api/v1`. Representative endpoints relevant to the features above:

Method	Endpoint	Description
POST	<code>/api/v1/admin/auth/login</code>	Admin login (email + password, then 2FA if enabled)
POST	<code>/api/v1/admin/auth/forgot-password</code>	Request a password reset link (FR-AD-32)
POST	<code>/api/v1/admin/auth/reset-password</code>	Complete a password reset using a valid token
GET	<code>/api/v1/products</code>	List/search products by name, SKU, or generic name (public + admin, FR-AD-31)
GET	<code>/api/v1/products/:id</code>	Get single product (public)
POST	<code>/api/v1/admin/products</code>	Create product (admin)
PUT	<code>/api/v1/admin/products/:id</code>	Update product incl. isNarcotic flag (admin)
DELETE	<code>/api/v1/admin/products/:id</code>	Delete product (admin)
PATCH	<code>/api/v1/admin/products/:id/narcotics</code>	Add/remove the Narcotics flag on a single product (admin)
PATCH	<code>/api/v1/admin/products/bulk/narcotics</code>	Bulk add/remove Narcotics flag across selected products (admin)
GET	<code>/api/v1/admin/products/narcotics</code>	List all products currently flagged as Narcotics (admin)
POST	<code>/api/v1/admin/products/import</code>	Bulk Excel import (admin)
GET	<code>/api/v1/admin/products/export</code>	Bulk Excel export (admin)
PATCH	<code>/api/v1/admin/products/bulk/price</code>	Bulk price update (admin)
PATCH	<code>/api/v1/admin/products/bulk/stock</code>	Bulk stock-status update (admin)
PATCH	<code>/api/v1/admin/products/:id/discount</code>	Set/clear a product-level discount (admin)
PATCH	<code>/api/v1/admin/categories/:id/discount</code>	Set/clear a category-level discount (admin)
PUT	<code>/api/v1/admin/settings/discount</code>	Set/clear the storewide discount (admin)
GET	<code>/api/v1/categories</code>	List categories (public)
POST	<code>/api/v1/admin/categories</code>	Create category (admin)
PUT	<code>/api/v1/admin/categories/:id</code>	Update category (admin)
DELETE	<code>/api/v1/admin/categories/:id</code>	Delete category (admin)
GET	<code>/api/v1/cities</code>	List active delivery cities + charges (public)
POST	<code>/api/v1/admin/cities</code>	Create city (admin)
PUT	<code>/api/v1/admin/cities/:id</code>	Update city (admin)
DELETE	<code>/api/v1/admin/cities/:id</code>	Delete city (admin)
POST	<code>/api/v1/otp/request</code>	Request email OTP (public)
POST	<code>/api/v1/otp/verify</code>	Verify email OTP (public)
POST	<code>/api/v1/orders/standard</code>	Submit a standard order (public)
POST	<code>/api/v1/orders/instant</code>	Submit an instant order with prescription (public)
POST	<code>/api/v1/orders/narcotics</code>	Submit a narcotics order with prescription (public)
GET	<code>/api/v1/admin/orders</code>	List/filter orders by type/status (admin)

Method	Endpoint	Description
GET	/api/v1/admin/orders/:id	Get order detail (admin)
PATCH	/api/v1/admin/orders/:id/status	Update order status (admin)
PATCH	/api/v1/admin/orders/:id/cancel	Cancel an order and trigger automatic void/refund (admin)
POST	/api/v1/admin/products/:id/images	Upload one or more additional images for a product (admin)
PATCH	/api/v1/admin/products/:id/images/:imageId/primary	Set an image as the product's primary/cover image (admin)
DELETE	/api/v1/admin/products/:id/images/:imageId	Remove a single product image (admin)
PATCH	/api/v1/admin/orders/:id/branch	Assign/update branch description (admin)
PATCH	/api/v1/admin/orders/:id/items	Add medicines/total to an Instant order (admin)
PATCH	/api/v1/admin/orders/:id/verification	Approve/reject a narcotics prescription (admin)
POST	/api/v1/payments/card/initiate	Initiate card payment (public/gateway callback)
POST	/api/v1/payments/card/capture	Capture a deferred narcotics card payment post-approval (system)
GET	/api/v1/admin/dashboard/overview	Dashboard summary cards (admin)
GET	/api/v1/admin/reports/sales	Sales report data (admin)
GET	/api/v1/admin/reports/export	Export sales report to Excel/PDF (admin)
GET	/api/v1/admin/activity-logs	List activity logs, filterable by entity/actor (admin)
GET	/api/v1/admin/settings/:group	Get a settings group (admin)
PUT	/api/v1/admin/settings/:group	Update a settings group (admin)
POST	/api/v1/admin/users	Create admin user — Super Admin only (admin)
GET	/api/v1/admin/users	List admin users (admin)
PUT	/api/v1/admin/users/:id	Edit an admin's role/module access — Super Admin only (admin)
DELETE	/api/v1/admin/users/:id	Delete an admin account — Super Admin only (admin)
POST	/api/v1/chatbot/message	Send a message to the AI symptom-assistant chatbot (public)

19. UI Requirements

19.1 Direction

Full design tokens and rationale live in the companion Design Direction document. In summary: a calm, trustworthy "modernized apothecary" look — deep green and a single warm amber accent rather than a generic clinical blue — with a recurring "label-stub" motif used to surface status (In Stock, Pending Verification, Instant Order, Narcotics) at a glance across both the storefront and the dashboard.

19.2 Requirements

- Fully responsive across mobile, tablet, and desktop for the customer website.
- Dense, sortable/filterable data tables for the admin dashboard, optimized for high order volume, with a product search-by-name/SKU field always visible (FR-AD-31).
- Narcotics-flagged products are shown with a badge/flyer on the product card — never as a separate navigable category — and pending-verification orders must be visually distinguishable at a glance, without being alarming (neutral card, red label-stub only).
- Placeholder imagery for any product without a photo — never a broken image.
- Motion used sparingly and purposefully; respects prefers-reduced-motion.
- Storefront pages are server-rendered (Next.js) with per-page titles/descriptions and Open Graph tags — see Section 19.3 for the full SEO plan this enables.

19.3 SEO & Discoverability

This is the direct reason the storefront is built in Next.js rather than a plain React SPA — none of the below is reliably achievable without server-rendered HTML.

- Auto-generated sitemap.xml (from the live product/category data) and robots.txt, submitted through Google Search Console.
- JSON-LD structured data: Product schema (price, stock, rating) on every product page, Organization and LocalBusiness schema site-wide — LocalBusiness matters most here, since it's what makes Medikart eligible to appear in local/map-pack results for Pakistani searches.
- Google Business Profile listing(s) for each physical branch, verified and kept current (hours, phone) — for a pharmacy, this typically drives as much visibility as the website itself.

Note: Technical SEO (this section) can be fully in place at launch. Actual ranking movement into the top 10–25 for competitive search terms realistically takes 3–6 months of ongoing content, local reviews, and backlink work on top of this foundation — worth setting that expectation with the client explicitly, so launch day isn't mistaken for the finish line.

20. Acceptance Criteria

AC-01: A guest can complete a Standard order (search → cart → OTP → COD or card → confirmation) end to end.

AC-02: Delivery charge is always PKR 250 for a configured city and PKR 500 otherwise, calculated server-side.

AC-03: An Instant Order can be submitted with just a prescription and contact details.

AC-04: A product carrying the Narcotics flag cannot be fulfilled or card-charged without an approved prescription, and never appears as a separate browsable category.

AC-05: An admin can flag a product as Narcotics and it is enforced on the very next order for that product — no deployment required.

AC-06: An admin can remove the Narcotics flag from a product and future orders for it no longer require verification.

AC-07: Every Narcotics flag change is visible in Activity Logs with admin, product, action, and timestamp.

AC-08: An order already placed is unaffected by a Narcotics flag change that happens afterward.

AC-09: An admin who forgets their password can reset it via a single-use emailed link without the new password ever being emailed in plain text (FR-AD-32).

AC-10: An admin can find any product by typing part of its name or SKU into the product search field (FR-AD-31).

AC-11: Every order syncs to the correct Google Sheets worksheet with all required columns.

AC-12: The client's real product Excel file (6,112 rows) imports with clear per-row error reporting, not a silent partial success.

AC-13: A repeated request for the same product listing is measurably faster on the second call, confirming Redis caching is actually active, not just configured.

AC-14: The discount-precedence, delivery-charge, narcotics-gate, and OTP logic each have passing automated unit tests before any production deployment (NFR-TEST-01).

AC-15: Uploaded product/prescription images are compressed and served from the VPS without requiring a third-party image CDN.

AC-16: A product with a 15% product-level discount shows that price even when its category or the whole store also has a discount active — the more specific discount always wins, never stacked.

AC-17: Removing a discount at any level correctly falls back to the next-broadest active discount, or full price if none remain.

AC-18: The discounted price shown on a product page matches the price actually charged at checkout — both computed server-side.

AC-19: A customer asking the chatbot about a symptom receives a product suggestion plus the 'not a doctor, consult a pharmacist' disclaimer every time, never just once per conversation.

AC-20: The chatbot never suggests a product carrying the Narcotics flag, under any phrasing of the question.

AC-21: A regular Admin account cannot create, delete, or edit another admin account or its own role — only a Super Admin can.

AC-22: The About and Contact Us pages reflect whatever content an admin has entered in Settings, without a code change.

AC-23: The WhatsApp icon is visible on every storefront page and opens a chat with the client's actual WhatsApp Business number.

AC-24: Cancelling a Pending or Packed COD order marks it Cancelled with no payment action needed.

AC-25: Cancelling a Pending or Packed card order that was only authorized (narcotics, unapproved) voids the hold — no money is ever captured.

AC-26: Cancelling a Pending or Packed card order that was already captured triggers a refund via the gateway using the original transaction reference.

AC-27: The customer receives exactly one cancellation email, distinct from the original order-confirmation email.

AC-28: An admin can upload a second and third image to a product and choose which one displays as the primary/cover image in listings.

AC-29: Hammering any single API endpoint (not just login/OTP) past its configured limit returns 429 with a Retry-After header, and the limit holds consistently across all clustered server processes.

AC-30: A request attempting to set a field it has no business setting (e.g. a checkout request including isNarcotic or price) is ignored/rejected, not silently accepted.

AC-31: A regular Admin token used directly against a Super-Admin-only API route is rejected, even bypassing the UI entirely.

21. Assumptions & Constraints

- Client supplies the product Excel file, city list, and delivery charges ahead of catalog-import testing.
- A PKR-capable card payment gateway is contracted separately and integrated behind an abstracted payments interface.
- Guest checkout only — no customer accounts, by explicit client requirement.
- Single Ubuntu VPS deployment for this phase.
- Product photography is AI-generated by the development team (the client will not supply a photo set); a placeholder image is still required as a fallback for any product missed in that process.
- Pharmacy staff are responsible for the clinical/regulatory judgment behind narcotics approvals — the system enforces the workflow, not the medical decision.

22. Future Enhancements

- Fixed named role presets (e.g. Product Manager, Order Manager, Sales Manager) layered on top of the module-level access already supported (FR-AD-38).
- Automatic low-stock tracking.
- Bulk product image upload matched by SKU, once images are supplied.
- Rule-based suggestions for Narcotics flagging (e.g. by category/keyword), with admin approval still required.
- Additional customer lifecycle emails, if requested.
- Multi-branch inventory visibility as the business expands.

23. Success Metrics

Metric	Target
Guest checkout completion rate (started → confirmed)	Track from launch; reduce checkout drop-off release over release.
Average order confirmation time (submit → confirmation email)	Under 1 minute end-to-end.
Google Sheets sync latency (order placed → row visible)	Under 2 minutes.
Narcotics orders reaching Delivered without an Approved verification	Zero, always.
Time for an admin to change a product's Narcotics status and have it enforced	Immediate — no deployment, no delay.
Bulk product import success rate on the client's real catalog	100% of valid rows imported; 0 silent failures.
Weekly report delivery reliability	100% of scheduled weeks, on schedule.

24. User Journeys

24.1 Guest Shopper — Standard Order

Amina needs paracetamol and a cough syrup tonight. She opens Medikart on her phone, searches "paracetamol," adds it and a cough syrup to her cart, and goes to checkout. She enters her name, phone, and address, gets an OTP by email, verifies it, chooses Cash on Delivery, sees the delivery charge for her city (PKR 250, since her city is configured), and places the order. She gets one confirmation email and waits for delivery — no account, no password to remember.

24.2 Prescription Customer — Instant Order

Bilal has a prescription from his doctor but doesn't know the exact brand names his pharmacist would normally stock. Instead of guessing through search, he selects Instant Order, photographs and uploads the prescription, fills in his details, verifies by OTP, and submits. A pharmacist reviews the prescription, adds the correct medicines and a total, and the order proceeds — Bilal never had to identify a single SKU himself.

24.3 Narcotics Customer

Hina's prescription includes a controlled medication the pharmacy has flagged as Narcotics. When she adds it to her cart, checkout requires her to upload the prescription before she can complete the order. Her order goes to Pending Verification; a pharmacist reviews and approves it, and only then — if she chose card payment — is her card actually charged. If the prescription had been invalid, she would never have been charged at all.

24.4 Pharmacy Admin — Narcotics Reclassification

A regulation update means a product the pharmacy previously sold freely now needs prescription control. The admin opens that product, flags it as Narcotics, and from that moment every new order for it is routed into verification — with no wait for a developer, no deployment, and a logged record of exactly who made the change and when, in case it's ever questioned.

25. Release Plan

Full phase detail, exit criteria, and estimates are maintained in the companion `phases.md` document; this is a summary view.

Phase	Focus
Phase 0	Foundation — repo, environments, design tokens.
Phase 1	Product catalog & bulk Excel import.
Phase 2	Standard order checkout, cities & delivery pricing.
Phase 3	Card payment integration.
Phase 4	Instant Orders & Narcotics workflow, including Narcotics flagging.
Phase 5	Admin dashboard depth — branch assignment, bulk ops, admin users, activity logs.
Phase 6	Integration polish — Google Sheets, weekly reports, Settings.
Phase 7	Sales reports.
Phase 8	Deployment & hardening.
Phase 9	Post-launch backlog / future enhancements.

26. Risks & Mitigations

Risk	Mitigation
A narcotics product is mistakenly left unflagged, allowing an unverified sale.	Bulk-flagging tools plus a dedicated Narcotics filtered view make it fast to audit the full flagged list at any time.
Google Sheets or SMTP has a temporary outage during checkout.	Both are queued/retried outside the order-placement request, so a customer's order is never blocked by a downstream integration hiccup.
The 6,000–8,000 row product import silently drops bad rows.	Import validates and reports per-row errors rather than failing or skipping silently.
A card is charged on a narcotics order before the prescription is approved.	Payment capture is a distinct step gated on an explicit Approved verification status — never bundled into order creation.
Staff lose track of which products are currently narcotics-controlled.	A dedicated Narcotics filtered view and full audit trail keep the current state and its history visible at all times.
The AI chatbot's product suggestion is read as medical advice rather than a shopping aid.	Mandatory disclaimer on every response, narcotics products excluded from suggestions entirely, and conversations logged for periodic review.
A former admin's account is left active with full access after they leave.	Super Admin can deactivate or delete any admin account immediately (FR-AD-37/38), independent of a developer.

27. Screen Inventory

Screen	Module
Home / Product Grid	Customer Website
Product Detail (incl. discount badge/strike-through)	Customer Website
Cart	Customer Website
Checkout (Details → OTP → Payment → Confirm)	Customer Website
Instant Order Upload	Customer Website
Narcotics Prescription Upload	Customer Website
Order Confirmation	Customer Website
About	Customer Website
Contact Us	Customer Website
AI Chatbot widget (global, floating)	Customer Website
WhatsApp click-to-chat icon (global, floating)	Customer Website
Login	Admin
Forgot Password / Reset Password	Admin
Dashboard Overview	Admin
Product List (with name/SKU search)	Admin — Products
Product Edit (incl. Narcotics toggle, discount field, multi-image upload)	Admin — Products
Narcotics Filtered View	Admin — Products
Bulk Import / Export	Admin — Products
Category List (incl. discount field)	Admin — Categories
Standard / Instant / Narcotics Orders	Admin — Orders
City List	Admin — Cities
Sales Reports	Admin — Reports
Admin Users (create/edit role & access/delete — Super Admin only)	Admin — Users
Settings (incl. Discount, Pages/About-Contact content)	Admin — Settings
Activity Logs	Admin — Logs